CASE STUDY

The FireEye Mandiant Intrusion of 2020: The Public Record

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

In late November 2020 a security alert at FireEye flagged something small: an employee's account had registered a second phone to receive two-factor codes, and the employee had not registered a new device (Confirmed [11]). More than 100 FireEye staff then worked the case around the clock for weeks (Confirmed [11]). On 8 December 2020 the company told the SEC and its blog readers on the same day that a highly sophisticated attacker, which it believed state-sponsored, had broken in and taken some of its Red Team assessment tools (Confirmed [1][2][3]). Within days, having run out of other leads, FireEye decompiled its own SolarWinds Orion server and found the implant it named SUNBURST (Confirmed [11][15]). That made its own breach the first public thread of the SolarWinds campaign (Inferred).

The public record of the FireEye intrusion is unusually rich because the victim was an incident-response firm that filed with the SEC, testified twice to Congress and published its own detection content. That record supports a few clear findings. The stolen tools held no zero-day exploits, many were already public, and FireEye released hundreds of free countermeasures and a ranked list of 16 CVEs to patch on the day it disclosed (Confirmed [1][3][4][8]). Through 23 February 2021 the company had seen no attacker use the tools (Confirmed [11]). The attacker went after information about certain government customers, and FireEye saw no exfiltration from its primary customer-data systems (Confirmed [1]). The intrusion was caught through the identity plane, and the techniques that mattered most to the wider campaign were identity techniques, from forged SAML tokens to added cloud application credentials (Confirmed [23][36]), and the same actor was still registering devices and abusing application credentials in 2024 (Confirmed [46][47]; Inferred for the pattern).

Attribution firmed in steps. FireEye named no country in 2020 (Confirmed [1]). The US government said "likely Russian in origin" in January 2021, named Russia's Foreign Intelligence Service (SVR) with high confidence in April 2021, and Mandiant merged its UNC2452 cluster into APT29 in April 2022 (Confirmed [22][26][31]). The company itself changed shape: FireEye sold its products business and renamed itself Mandiant in October

2021, and Google completed its acquisition of Mandiant in September 2022 (Confirmed [49][50][53]). The merger proxy dates the products-business divestment idea to 2019 and does not tie the split to the intrusion (Confirmed [51]).

This study is the home for the FireEye intrusion itself: detection, disclosure, the stolen tools, the countermeasures and the identity lessons. The SolarWinds Orion supply chain and ATT&CK campaign C0024 have their home in the SolarWinds and SUNBURST study; Part 4 summarizes Orion in one paragraph and links there.

Key facts at a glance

Item	Detail	Grade
Victim	FireEye, Inc. (renamed Mandiant, Inc. in October 2021; part of Google since September 2022)	Confirmed [49][53]
Detection	Late November 2020: an alert that an employee account had registered a second phone for two-factor codes	Confirmed [11]
Investigation	More than 100 employees around the clock (Senate statement); "nearly 100" and "almost 100" in oral testimony	Confirmed [11][13][12]
Disclosure	8 December 2020, Form 8-K Item 8.01 and blog posts on the same day	Confirmed [1][2][3]
Actor as described in 2020	Highly sophisticated, believed state-sponsored; "a nation with top-tier offensive capabilities"; no country named	Confirmed [1]
Initial access	Trojanized SolarWinds Orion updates, per FireEye's 10-K for fiscal 2020	Confirmed [25]
What was taken	Certain Red Team assessment tools; the attacker also reached some internal systems and primarily sought information on certain government customers	Confirmed [1]
What was not seen taken	No evidence of exfiltration from the primary systems holding incident-response or consulting customer data, or product threat-intelligence metadata	Confirmed [1]
Zero-days in the stolen tools	None	Confirmed [1][3][10]
Countermeasures	More than 300 (8-K), hundreds (blog), 324 rules in the final public table, more than 500 by February 2021 (testimony)	Confirmed [1][3][11]; Demonstrated [6]
CVEs to patch	A ranked list of 16; all 16 are now in CISA's KEV catalog	Confirmed [8][9]
Use of the stolen tools	None seen by FireEye through 23 February 2021; later use not checked	Confirmed [11]
Link to SolarWinds	FireEye found SUNBURST, told SolarWinds on 12 December 2020 and published on 13 December	Confirmed [11][15]
Attribution	US: SVR, high confidence, 15 April 2021; UK NCSC: SVR "highly likely"; Mandiant: UNC2452 merged into APT29, 27 April 2022	Confirmed [26][29][31]
Financial effect	No material effect on Q4 or FY2020 revenue or operating expenses, per the 10-K	Confirmed [25]
ATT&CK objects	Group G0016 APT29; campaign C0024 SolarWinds Compromise	Confirmed [32][33]

Key findings

- **A device-registration alert caught a nation-state operator.** The first signal was a second phone added to an employee's two-factor enrollment (Confirmed [11]). At the Senate hearing, Senator Blunt called the extra verifier the tip-off and Mandia agreed (Confirmed [12]).

- **The theft was real but its weight was limited.** The tools held no zero-days, many were public or already in FireEye's open-source CommandoVM, and some were public tools modified to evade basic detection (Confirmed [3]). FireEye did not believe the theft would greatly advance the attacker's overall capabilities (Confirmed [3]).
- **The defenders' answer shipped with the disclosure.** The countermeasures repository was created on 3 December 2020, five days before disclosure, and received its first import on 8 December (Demonstrated [4]). It carried Snort, Yara, ClamAV and HXIOC rules and a ranked list of 16 CVEs (Confirmed [4][8]).
- **The most useful mitigation was patching known bugs.** Every one of the 16 CVEs had a public record and a vendor fix before 8 December 2020 (Inferred [8]), and all 16 sit in CISA's KEV catalog, 11 of them marked as known ransomware use (Confirmed [9]).
- **FireEye was a "stage two" victim.** Mandia used that phrase for a company entered through the SolarWinds implant (Confirmed [12]). The attackers went for credentials and tokens first, bypassed two-factor authentication and moved into Office 365 to target email and documents (Confirmed [12]).
- **Attribution was a ladder, not a jump.** "Nation with top-tier offensive capabilities" (December 2020), "likely Russian in origin" (January 2021), the SVR "with high confidence" (April 2021), APT29 (April 2022) (Confirmed [1][22][26][31]).
- **The identity techniques outlived the campaign.** Device registration appears in the record in 2020, 2022 and 2024, added application credentials in 2020 to 2021 and 2024, and federation-trust changes in 2020 to 2021 (Confirmed [11][23][32][45][46][47]; Inferred for the continuity).

Top recommendations

1. **Alert on MFA device registration.** Treat a new authenticator on an existing account as a security event, put conditional access on MFA registration, and give every active account an enrolled device so a dormant account cannot be self-enrolled (Confirmed [11][45]; Inferred for the alerting rule).
2. **Protect the federation layer as tier zero.** Watch for new or changed domain federation, credentials added to service principals and access to the AD FS key container; after compromise, rotate the token-signing certificate with care, since one rotation leaves the old certificate valid during a grace period, and reset krbtgt twice (Confirmed [23][41][37]).
3. **Patch the 16 CVEs if any remain.** FireEye ranked them to limit its own stolen tools; they are all on KEV (Confirmed [8][9]).
4. **Use published detection content as a lesson in technique, not a shield.** Practitioners at the time urged defenders to study the rules for the techniques they expose, and warned that an adversary of this kind could evade published indicators (Reported [58]).
5. **Disclose early and ship detection with the disclosure.** FireEye's same-day 8-K, blog and free rules gave defenders something to act on at once (Confirmed [1][3][4]; Inferred for the recommendation).

Scope and method

This study covers the intrusion into FireEye disclosed on 8 December 2020: its detection, the investigation, the stolen Red Team tools and the countermeasures, FireEye's discovery of SUNBURST, the attribution record, the government and corporate aftermath through the Google acquisition of 2022, and the identity-plane techniques that recur in the same actor's record through 2024. It draws on FireEye's and Mandiant's SEC filings, blog posts and GitHub repositories; Kevin Mandia's prepared statement and the transcripts of the Senate and House hearings of February 2021; CISA alerts, advisories and directives; White House, Treasury and UK NCSC statements; vendor reports from Microsoft, CrowdStrike, Volexity, Palo Alto Networks Unit 42, Malwarebytes and IBM; SolarWinds' own blog; earlier security-vendor breach disclosures from RSA (via EMC), Bit9 and Kaspersky; the live MITRE ATT&CK record; and the library's own data files. Every source was opened on 11 November 2026. Quotations are kept to a few words. The study describes tradecraft at the level the advisories use and reproduces no rule content, command or payload.

Where the record overlaps with another study, the topic lens decides the home. SolarWinds and SUNBURST is the home for the Orion build compromise and campaign C0024, and already records the 8 December 2020 disclosure and the more than 300 countermeasures (Demonstrated [69]); The Year 2020 in Intrusions carries a one-line FireEye entry; Russia-Attributed Threat Actors covers APT29 across its whole history. The Shadow Brokers releases of 2016 and 2017, which commentators compared to this theft, and the 2015 Hacking Team leak have their dated record in The Zero-Day Trade and Its Fallout; the Shadow Brokers releases are also summarized in United States-Attributed Threat Actors.

Grade	Meaning
Confirmed	A primary source was opened: the company's own filing, blog or repository, a government agency, a hearing transcript, a vendor that observed the activity, or the MITRE record itself
Reported	Known only through a secondary source, such as press coverage or a quotation in a news article, attributed to that outlet
Demonstrated	This study counted or checked it directly, for example repository metadata, rule tables or the library's data files
Inferred	This study's own reasoning from the cited facts, labelled where it appears

Two rules matter for this incident. First, FireEye's own counts of its countermeasures differ across its statements, so every figure is cited with its date and source rather than reconciled. Second, attribution language is carried through as each source wrote it: "state-sponsored", "likely Russian in origin", "highly likely" and "high confidence" are different claims made months apart.

Part 1: the intrusion at FireEye

Detection

Mandia's prepared statement to the Senate Select Committee on Intelligence gives the starting point: FireEye first identified the intrusion in late November 2020, when a peculiar alert showed that an employee's account had registered a second phone to receive two-factor codes; the employee had not registered a new device (Confirmed [11]). The same statement says early signs showed the attackers were likely working for and trained by a foreign intelligence service (Confirmed [11]).

At the hearing itself Mandia filled in the sequence. The attackers entered through the SolarWinds implant, went for credentials and tokens first, bypassed FireEye's two-factor authentication, and then moved into Office 365 to target email and documents (Confirmed [12]). Senator Blunt called the extra MFA verifier "the tip off", and Mandia agreed (Confirmed [12]). FireEye's own investigation team numbered more than 100 people working around the clock in the prepared statement (Confirmed [11]), "nearly 100" in the House oral testimony (Confirmed [13]) and "almost 100" in the Senate oral testimony (Confirmed [12]).

Mandia testified that the actors showed constraint and focus, going after specific information and specific people as if working to collection requirements, and that this helped FireEye conclude it faced a foreign intelligence actor (Confirmed [11]). He also said FireEye runs over 600 red teams a year (Confirmed [12]).

Disclosure

On 8 December 2020 FireEye filed a Form 8-K under Item 8.01 and posted to its blog at the same time (Confirmed [1][2]). The filing said a highly sophisticated threat actor had attacked the company, that the actor's discipline, operational security and techniques led FireEye to believe the attack was state-sponsored, and that Mandia had concluded a nation with top-tier offensive capabilities was behind it (Confirmed [1]). No country was named (Confirmed [1]). The filing said FireEye was investigating in coordination with the FBI and other key partners, including Microsoft (Confirmed [1]).

Mandia's 8 December blog post said the attackers tailored their capabilities to FireEye, operated clandestinely using methods that counter security tools and forensic examination, and used a novel combination of techniques that FireEye and its partners had not seen before (Confirmed [2]). The post's original URL now redirects to an unrelated page, so it was read from the Wayback capture of 1 January 2021 (Confirmed [2]). A second post the same day, "Unauthorized Access of FireEye Red Team Tools", carried the technical detail and is now served from cloud.google.com under the threat-intelligence section, credited to FireEye (Confirmed [3]; Demonstrated [3]).

What the attacker went after, and what FireEye did not see taken

The 8-K says the attacker targeted and accessed certain Red Team assessment tools that FireEye uses to test customers' security, and that none of the tools contained zero-day exploits (Confirmed [1]). Consistent with a nation-state espionage effort, the attacker primarily sought information related to certain government customers (Confirmed [1]). The attacker reached some internal systems, but FireEye had seen no evidence that data was exfiltrated from its primary systems holding incident-response or consulting customer information, or from the product metadata in its dynamic threat intelligence systems (Confirmed [1]).

FireEye's 10-K for fiscal 2020 adds the access path: the attacker got into FireEye's networks and systems through trojanized SolarWinds Orion updates and accessed certain internal systems (Confirmed [25]). It says FireEye notified affected customers and government agencies as it deemed required or appropriate, that the incident did not materially affect Q4 or FY2020 revenue or operating expenses, and that FireEye did not expect a material impact going forward (Confirmed [25]).

Mandia's House testimony describes three stage-two actions across the campaign: key theft, focused targeting of documents and email, and theft of source code or tools, which at FireEye meant its assessment tools (Confirmed [13]). Mandiant's 2022 merge report adds a campaign-level detail: in 2020, about five days after the SolarWinds compromise was made public, APT29 moved a persistent BEACON backdoor to another system in one victim's network after that victim's security team emailed its IT administrators. The report does not name the victim (Confirmed [31]).

No opened source says forged SAML tokens were used inside FireEye's own environment, and Mandia did not mention Golden SAML in testimony, so token forgery is documented here at campaign level only (Inferred [12]).

Part 2: the timeline

One row per dated event or report. Orion build events are included for orientation; their detail lives in the SolarWinds study.

Date	Event	Source	Grade
2019	FireEye's board explores divesting the products business (it begins actively pursuing the sale in early 2021)	[51]	Confirmed
Aug 2019	First Seen date of ATT&CK campaign C0024 SolarWinds Compromise	[32]	Confirmed
Sep 2019	Earliest suspicious activity on SolarWinds' internal systems, per SolarWinds	[18]	Confirmed
Oct 2019	An Orion Platform release carries test modifications; Mandia calls it innocuous test code; Unit 42 dates code modification to as early as October 2019	[18][13][35]	Confirmed
20 Feb 2020	SUNBURST insertion into Orion builds begins; SUNSPOT's likely build timestamp	[18][19]	Confirmed
Mar 2020	Working implant by March (Mandia); CISA dates the activity to at least March 2020	[13][20]	Confirmed
24 Mar 2020	Trojanized BusinessLayer DLL signed, in Orion Core 2019.4.5220 Hotfix 5	[15]	Confirmed
Mar to May 2020	Trojanized updates signed and posted	[15]	Confirmed
Spring 2020	Indications of compromise at multiple organizations date back to spring 2020, per FireEye	[14]	Confirmed
Jun 2020	The perpetrators remove the SUNBURST code from SolarWinds' environment	[18]	Confirmed
19 Nov 2020	A $400 million Blackstone and ClearSky investment in FireEye is announced (it closes on 11 Dec 2020)	[51]	Confirmed
Late Nov 2020	FireEye's alert: a second phone registered for an employee's two-factor codes	[11]	Confirmed
3 Dec 2020	red_team_tool_countermeasures repository created on GitHub (00:31:44 UTC)	[4]	Demonstrated
8 Dec 2020	Form 8-K and two blog posts disclose the attack and the tool theft; countermeasures first imported (20:02:46 UTC) with 311 rules; CVE list committed (22:36:26 UTC); CISA alert	[1][2][3][4][5][8][10]	Confirmed; Demonstrated for repository times and counts

Date	Event	Source	Grade
8 Dec 2020	FireEye shares fall nearly 8 percent after hours, per SecurityWeek	[60]	Reported
10 Dec 2020	First rule update; Malwarebytes adds the tools to its detection databases using FireEye's rules; an IBM Security Community post maps the CVEs and Snort rules into QRadar	[6][55][56]	Demonstrated; Confirmed
12 Dec 2020	FireEye tells SolarWinds that Orion is compromised; SolarWinds' CEO reports to CISA the same day	[11][13]	Confirmed
13 Dec 2020	FireEye publishes the SUNBURST report (UNC2452) and indicators; sunburst_countermeasures created (15:10:47 UTC) with its initial release at 22:33:55 UTC; CISA Emergency Directive 21-01	[15][16][21]	Confirmed; Demonstrated for repository times
14 Dec 2020	FireEye 8-K reproduces the 13 Dec update; Microsoft MSRC customer guidance; Volexity reports Dark Halo; first rule update after SUNBURST	[14][36][38][6]	Confirmed
17 Dec 2020	CISA AA20-352A first published	[20]	Confirmed
18 Dec 2020	ED 21-01 supplemental guidance; countermeasures rule update	[21][6]	Confirmed
21 Dec 2020	Microsoft's recovery advice for systemic identity compromise	[41]	Confirmed
23 Dec 2020	Unit 42 SolarStorm timeline	[35]	Confirmed
24 Dec 2020	FireEye's SUNBURST additional technical details, including the kill switch	[17]	Confirmed
30 Dec 2020	Final countermeasures table: 324 rules across 61 tool families; further ED 21-01 guidance	[6][21]	Demonstrated; Confirmed
31 Dec 2020	Microsoft: one internal account viewed source code without permission to change it	[42]	Confirmed
5 Jan 2021	FBI, CISA, ODNI and NSA joint statement: "likely Russian in origin"	[22]	Confirmed
6 Jan 2021	ED 21-01 supplemental guidance	[21]	Confirmed
8 Jan 2021	CISA AA21-008A on post-compromise activity in Microsoft cloud environments	[37]	Confirmed
11 Jan 2021	CrowdStrike publishes its SUNSPOT analysis (StellarParticle, unattributed)	[19]	Confirmed
13 Jan 2021	Mandiant-Azure-AD-Investigator repository created	[24]	Confirmed

Date	Event	Source	Grade
19 Jan 2021	Mandiant's Microsoft 365 remediation and hardening paper	[23]	Confirmed
23 Feb 2021	Senate Select Committee on Intelligence hearing; Mandia's prepared statement	[11][12]	Confirmed
26 Feb 2021	House hearing "Weathering the Storm"; FireEye 10-K for fiscal 2020 names the Orion access path	[13][25]	Confirmed
4 Mar 2021	Microsoft names NOBELIUM and its GoldMax, GoldFinder and Sibot malware	[40]	Confirmed
15 Apr 2021	White House names the SVR; Treasury sanctions; UK NCSC statement; NSA, CISA and FBI advisory; AA20-352A and AA21-008A revised	[26][27][28][29][20][37]	Confirmed
22 Apr 2021	ED 21-01 supplemental guidance	[21]	Confirmed
26 Apr 2021	CISA, FBI and DHS AA21-116A on SVR tradecraft	[30]	Confirmed
12 May 2021	Executive Order 14028	[43]	Confirmed
29 May 2021	FireEye agrees to sell its products business for $1.2 billion (8-K filed 2 Jun 2021)	[48]	Confirmed
4 to 8 Oct 2021	FireEye, Inc. becomes Mandiant, Inc. (4 Oct); ticker FEYE becomes MNDT (5 Oct); products sale closes (8 Oct)	[49][50]	Confirmed
28 Oct 2021	Mandiant adds EWS Impersonation and cloud solution provider abuse to its Microsoft 365 paper	[23]	Confirmed
3 Nov 2021	CISA's KEV catalog opens; 15 of FireEye's 16 CVEs added	[9]	Confirmed
27 Jan 2022	CrowdStrike's StellarParticle observations	[39]	Confirmed
3 Mar 2022	CVE-2018-8581 added to KEV, completing the 16	[9]	Confirmed
7 Mar 2022	Mandiant agrees to be acquired by Google LLC	[52][53]	Confirmed
27 Apr 2022	Mandiant merges UNC2452 into APT29; a May 2022 note on the SUNBURST report follows	[31][15]	Confirmed
18 Aug 2022	Mandiant reports APT29 self-enrolling MFA on a dormant mailbox	[45]	Confirmed
12 Sep 2022	Google completes the Mandiant merger	[53]	Confirmed
12 Jan 2024	Microsoft detects Midnight Blizzard in its corporate environment (published 25 Jan)	[47]	Confirmed

Date	Event	Source	Grade
26 Feb 2024	AA24-057A: SVR actors adapt tactics for initial cloud access	[46]	Confirmed
22 Oct 2024	SEC charges four companies over misleading disclosures of intrusions by the actor likely behind the Orion hack	[44]	Confirmed
8 May 2025	red_team_tool_countermeasures archived	[4]	Confirmed
31 Jul 2026	ATT&CK C0024 v1.1 last modified	[32]	Confirmed

Part 3: the stolen tools and the countermeasures

What FireEye said the tools were

FireEye described the stolen tools as ranging from simple reconnaissance scripts to whole frameworks similar to Cobalt Strike and Metasploit (Confirmed [3]). Many were already public, some through its open-source CommandoVM distribution; some were public tools modified to evade basic detection; others were built in-house (Confirmed [3]). The company said the tools apply well-known, documented methods used by other red teams, that it did not know whether the attacker would use or publicly disclose them, and that it did not believe the theft would greatly advance the attacker's overall capabilities (Confirmed [3]). None of the opened FireEye statements itemizes which tools were taken (Inferred [1][3][6]).

CISA's alert the same day repeated that the tools contained no zero-days, said it had received no reports of malicious use, warned that third parties could misuse them to take control of targeted systems, and told practitioners to read FireEye's two posts and use the GitHub countermeasures (Confirmed [10]). CISA's alert still links the old github.com/fireeye path (Demonstrated [10]).

The countermeasures repository

FireEye released the countermeasures in OpenIOC, Yara, Snort and ClamAV formats, built them into its products, and shared them with partners and government agencies including DHS (Confirmed [3]). The repository README labels each rule Production (minimal tuning needed) or Supplemental (environment tuning or hunting use) and places the entire risk as to quality and performance on the user (Confirmed [4]).

Point in the record	Count	Breakdown	Source	Grade
8-K, 8 Dec 2020	More than 300 countermeasures	Not broken down	[1]	Confirmed
Blog, 8 Dec 2020	Hundreds	OpenIOC, Yara, Snort, ClamAV	[3]	Confirmed
First table of contents, commit b39b169, 8 Dec 2020	311 rules, 60 tool families	165 Yara, 88 HXIOC, 34 Snort, 24 ClamAV	[5]	Demonstrated
Final table of contents, commit 1b90ba7, 30 Dec 2020	324 rules, 61 tool families	172 Yara, 88 HXIOC, 40 Snort, 24 ClamAV; 233 Production, 88 Supplemental, 3 New	[6]	Demonstrated
Mandia prepared statement, 23 Feb 2021	More than 500 countermeasures	Not broken down	[11]	Confirmed

Point in the record	Count	Breakdown	Source	Grade
sunburst_countermeasures, from 13 Dec 2020	42 signature rows	28 Snort, 9 Yara, 4 HXIOC, 1 ClamAV	[16]	Demonstrated

The rule set was updated on 10, 14, 18 and 30 December 2020 (Demonstrated [6]). The three headline counts probably measure different sets; the 500 figure most likely also counts the SUNBURST rules and later updates (Inferred [11][6][16]). Each figure is therefore given here with its date.

The rule folders name 61 tool families (Confirmed [7]). Among them are BEACON (Cobalt Strike profiles), REDFLARE and GORAT, RUBEUS, SAFETYKATZ, IMPACKETOBF (obfuscated Impacket), SHARPZEROLOGON, PUPPYHOUND (which includes a SharpHound rule), DUEDLLIGENCE, MATRYOSHKA, PGF, SHARPERSIST, SHARPIVOT, KEEFARCE, DSHELL, EXCAVATOR and LNKSMASHER (Confirmed [7][6]). Some of these are public offensive tools that ATT&CK tracks as software: S0154 Cobalt Strike, S1071 Rubeus, S0357 Impacket and S0521 BloodHound (Demonstrated [67]). Reading those rule families as evidence of which public tools were in the stolen kit is this study's inference: a rule shows FireEye wanted to detect a tool family, not that a copy of it left the building (Inferred [6]).

As of 11 November 2026 the repository sits under the mandiant GitHub organization, is archived and BSD-2-Clause licensed, and shows 2,662 stars and 820 forks (Demonstrated [4]). The repository's creation five days before the disclosure suggests the release was prepared before the announcement (Inferred [4]).

How defenders used them

Within two days the content was in other products. Malwarebytes said it used FireEye's rules and code to add the tools to its detection databases, and compared the leak risk with the 2017 Shadow Brokers leak (Confirmed [55]). An IBM Security Community post showed QRadar mapping 14 of the listed CVEs to existing device QIDs, a rule over 33 Snort rule IDs from the repository, and hash reference sets filled from the repository's hash file (Confirmed [56]).

The practitioner response quoted in the press was mostly positive and mostly cautious (Inferred from [57][58]). Dave Aitel told Wired that very few teams have detections ready if their own tools leak, and called that part of FireEye's response very impressive (Reported [57]). CSO reported that many security experts applauded the release; Robert Lee of Dragos urged defenders to study the rules for the techniques they expose, while Mike Wiacek of Stairwell said such an adversary could trivially evade published indicators (Reported [58]). Roger Hale of BigID told CSO that the risk is not mitigated until countermeasures are deployed, and only until the tools are modified (Reported [58]).

How big a theft was it?

Commentators reached for the 2017 Shadow Brokers leak of NSA tools. Wired argued the theft was a statement but not a catastrophe, with fallout that does not compare to the Shadow Brokers leak, which included EternalBlue, or to the 2015 Hacking Team breach (Reported [57]). Richard Bejtlich told Wired that red team tools rank below customer data and sources-and-methods data in value (Reported [57]). Jake Williams told Wired the tools likely give Russia little it lacks, but that a public dump would put them in everyone's threat model (Reported [57]). Tod Beardsley of Rapid7 told CSO his first thought was the Shadow Brokers dump and WannaCry, but that FireEye's tools looked mostly like incremental improvements to public techniques (Reported [58]). Schneier's blog quotes the New York Times calling it the biggest known theft of cybersecurity tools since the Shadow Brokers, adding that the NSA tools were most likely more useful; the Times page itself returned 403, so that claim rests on the quotation (Reported [59]). (The Shadow Brokers began publishing in 2016; the EternalBlue release was April 2017.) For the Shadow Brokers and Hacking Team leaks themselves, see The Zero-Day Trade and Its Fallout, and for the Shadow Brokers in the actor view, United States-Attributed Threat Actors.

Wired also reported that the Washington Post attributed the breach to APT29, also called Cozy Bear, of Russia's SVR; the Post article was not opened (Reported [57]).

Were the tools used?

FireEye reported no evidence that any attacker had used the stolen tools on 8 December 2020 (Confirmed [1]) and again in testimony on 23 February 2021 (Confirmed [11]). CISA had received no reports of malicious use as of its alert (Confirmed [10]). No later primary statement of in-the-wild use was found when the sources were swept on 11 November 2026; use after February 2021 was not checked further (Confirmed [10][11]; not checked after February 2021).

Part 4: from FireEye to SUNBURST

SolarWinds Orion (summary; home study SolarWinds and SUNBURST, 2019 to 2021). SolarWinds dates the earliest suspicious activity on its systems to September 2019 and a test insertion to an October 2019 release; SUNBURST went into Orion builds from 20 February 2020 and the attackers removed the code in June 2020 (Confirmed [18]). CrowdStrike's SUNSPOT analysis describes the build implant that swapped one Orion source file for a backdoored version just before compilation (Confirmed [19]). FireEye says the trojanized updates were signed and posted between March and May 2020, and describes the TEARDROP memory-only dropper deploying a customized Cobalt Strike BEACON (Confirmed [15]). CISA lists the affected versions as Orion 2019.4 HF 5 through 2020.2 HF 1 and says there were initial access vectors other than Orion (Confirmed [20]). Mandia told the House that about 17,000 organizations downloaded the implant and the attackers manually engaged about 100 organizations and nine agencies (Confirmed [13]). The rest of the Orion record, including SUNSPOT, the cloud follow-on and the policy aftermath, is in the home study.

How FireEye found the implant

After running out of other investigative leads, FireEye forensically analyzed one of its own SolarWinds servers (Confirmed [11]). Mandia told the House that FireEye decompiled the platform, over 18,000 files of which 3,500 were executables, and found the implant in Orion updates, which it named SUNBURST (Confirmed [13][11]). In the Senate he described the earliest evidence of compromise leading to a SolarWinds server whose update they decompiled (Confirmed [12]). FireEye informed SolarWinds on 12 December 2020; SolarWinds confirms it was informed that day, and its CEO testified that SolarWinds reported to CISA the same day (Confirmed [11][13]).

Publication and the kill switch

On 13 December FireEye published indicators and detections (Confirmed [11]) and a technical post that tracked the campaign as UNC2452 (Confirmed [15]). The post describes dormancy of up to two weeks, DGA-based C2 traffic that mimics Orion API traffic, and the TEARDROP dropper (Confirmed [15]). The sunburst_countermeasures repository was created that afternoon, UTC (Demonstrated [16]). FireEye's 8-K of 14 December reproduced the update: a global supply-chain campaign delivered through Orion updates, compromises dating back to spring 2020, intrusions that needed manual interaction and did not self-propagate, and coordination with SolarWinds and the FBI (Confirmed [14]).

FireEye worked with GoDaddy and Microsoft to trigger a SUNBURST kill switch (Confirmed [11]). FireEye's 24 December technical post explains the mechanism at the level the vendor wrote it: certain DNS responses permanently disable the backdoor, and the DGA domain was redirected to a sinkhole chosen to inoculate infected installs (Confirmed [17]). Mandia's statement is clear about the limit: the kill switch made the backdoor hard or impossible to use but did not remove intruders already inside networks (Confirmed [11]).

Part 5: identity, aliases and attribution

Many names for one actor

FireEye and Mandiant tracked the activity as UNC2452 (Confirmed [15]), and ATT&CK lists UNC2452 among the associated names of G0016 APT29, which it attributes to Russia's SVR (Confirmed [33]; Demonstrated [68]). The other vendors' names for the same activity, such as Dark Halo, SolarStorm, StellarParticle and NOBELIUM, are set out in the SolarWinds and SUNBURST study.

The attribution ladder

Date	Who	Words used	Source	Grade
8 Dec 2020	FireEye	Highly sophisticated, believed state-sponsored; "a nation with top-tier offensive capabilities"; no country	[1]	Confirmed
13 Dec 2020	FireEye	UNC2452; no country	[15]	Confirmed
5 Jan 2021	FBI, CISA, ODNI, NSA	"likely Russian in origin"; "an intelligence gathering effort"	[22]	Confirmed
23 Feb 2021	Mandia (Senate)	Forensics most consistent with cyber espionage behaviors seen out of Russia; later in the hearing, "we shouldn't have to defend ourselves from the SVR"	[12]	Confirmed
4 Mar 2021	Microsoft	NOBELIUM	[40]	Confirmed
15 Apr 2021	White House	The SVR, "also known as APT 29, Cozy Bear, and The Dukes", high confidence	[26]	Confirmed
15 Apr 2021	UK NCSC	SVR "highly likely" responsible	[29]	Confirmed
15 Apr 2021	Treasury	Attributes the 2020 Orion exploit to the SVR	[27]	Confirmed
26 Apr 2021	CISA, FBI, DHS	SVR actors, aka APT 29, the Dukes, CozyBear, Yttrium	[30]	Confirmed
27 Jan 2022	CrowdStrike	StellarParticle associated with COZY BEAR (APT29), no confidence stated	[39]	Confirmed
27 Apr 2022	Mandiant	UNC2452 merged into APT29, based on firsthand data; APT29 assessed to be sponsored by the SVR	[31]	Confirmed

Mandiant's merge post is dated 27 April 2022, while the 13 December 2020 report carries an "UPDATE (May 2022)" note for the same merge (Confirmed [31][15]). ATT&CK's C0024 records the April 2021 US and UK attribution to the SVR (Confirmed [32]).

Who else was hit

Mandia put the number of organizations actually breached at 60-plus to about 100, against roughly 18,000 Orion customers affected (Confirmed [12][22]). The differing population figures, the federal agencies hit and Microsoft's source-code finding are covered in the SolarWinds and SUNBURST study.

Part 6: the government and corporate record

The emergency response

CISA's 8 December alert pointed defenders to FireEye's countermeasures (Confirmed [10]). Emergency Directive 21-01 and advisory AA20-352A, the federal response to the Orion compromise, are covered in the SolarWinds and SUNBURST study, and their dates are in the Part 2 timeline (Confirmed [20][21]).

The hearings

Mandia's prepared statement to the Senate Select Committee on Intelligence (23 February 2021) recounts detection, disclosure and the countermeasures, the 12 December notice to SolarWinds, the 13 December indicators and the kill switch (Confirmed [11]). It recommends a confidential, non-punitive threat and breach reporting program modeled on the FAA's Aviation Safety Reporting System, with liability protections for private-sector reporters (Confirmed [11]). At the joint House Oversight and Homeland Security hearing "Weathering the Storm" (26 February 2021), Mandia said FireEye was breached through the SolarWinds implant (Confirmed [13]).

Sanctions and policy

On 15 April 2021 the White House formally named the SVR, said the compromise gave it the ability to spy on or disrupt more than 16,000 systems worldwide, announced a new sanctions executive order and the expulsion of ten Russian diplomatic personnel, and pointed to the NSA, CISA and FBI joint advisory (Confirmed [26]). Treasury sanctioned six Russian technology companies: Positive Technologies, ERA Technopolis, Pasit, SVA, Neobit and AST (Confirmed [27]). The joint advisory lists five CVEs exploited by SVR actors: CVE-2018-13379, CVE-2019-9670, CVE-2019-11510, CVE-2019-19781 and CVE-2020-4006; this comes from the CISA summary page, and the NSA PDF was not opened (Confirmed [28]). Three of those five are also on FireEye's list of 16 (Inferred [8][28]).

Executive Order 14028 of 12 May 2021 removes contract barriers so IT and OT service providers, including cloud providers, share threat and incident information with CISA, the FBI and the intelligence community; establishes the Cyber Safety Review Board; and requires agencies to adopt MFA and plan Zero Trust Architecture (Confirmed [43]). The order's text does not name SolarWinds or FireEye (Confirmed [43]).

In October 2024 the SEC charged Unisys ($4 million), Avaya ($1 million), Check Point ($995,000) and Mimecast ($990,000) with misleading disclosures about intrusions by the actor likely behind the Orion hack; the companies neither admitted nor denied the findings (Confirmed [44]). Set beside those cases, FireEye's same-day disclosure, blog and free countermeasures sit early in a line of public disclosure that also includes Microsoft's December 2020 update, EO 14028's sharing provisions and the SEC's 2024 cases. No opened primary source draws that line or ties the later steps to FireEye, and Part 7 shows that RSA, Bit9 and Kaspersky had also disclosed their own breaches publicly (Inferred [1][42][43][44][61][64][66]).

The company afterwards

Date	Event	Source	Grade
2019 to early 2021	Board explores, then actively pursues, divesting the products business	[51]	Confirmed
19 Nov 2020 to 11 Dec 2020	$400 million Blackstone and ClearSky investment announced, then closed	[51]	Confirmed
29 May 2021	Agreement to sell the products business for $1.2 billion in cash to Polaris Buyer LLC, organized by a consortium led by Symphony Technology Group; 8-K filed 2 Jun 2021	[48]	Confirmed
4 and 5 Oct 2021	FireEye, Inc. renamed Mandiant, Inc.; ticker FEYE becomes MNDT; EDGAR records the FireEye name until 22 Sep 2021	[49][50]	Confirmed
8 Oct 2021	Products sale closes	[50]	Confirmed
7 Mar 2022	Google LLC agrees to acquire Mandiant at $23.00 per share in cash, about $5.4 billion including net cash, a 57 percent premium; Mandiant to join Google Cloud	[52]	Confirmed
12 Sep 2022	Merger completed; Mandiant a wholly owned subsidiary of Google	[53]	Confirmed

The merger proxy does not tie the split to the December 2020 intrusion (Confirmed [51]), and the 10-K reported no material financial effect from it (Confirmed [25]). Reading the sale as a consequence of the breach is not supported by the opened record (Inferred).

Part 7: security vendors as targets

FireEye was not the first security company to disclose a breach by a sophisticated actor; SecurityWeek framed its predecessors as nation-state-backed intrusions (Reported [60]). SecurityWeek named Kaspersky (2015, Duqu), RSA Security (2011), Symantec (2012) and Bit9 (2013) as predecessors (Reported [60]); CSO listed Kaspersky Lab, Bit9 and Avast (Reported [58]). Three of those cases have primary disclosures that could be opened.

Case	What the vendor said happened	What was taken	Product or code compromised?	Source	Grade
RSA, 2011	An extremely sophisticated APT attack; two phishing emails over two days carried an Excel file with a then-zero-day Adobe Flash exploit (CVE-2011-0609); a Poison Ivy variant (S0012) gave remote access	Information including information related to SecurID two-factor products	RSA said it could reduce SecurID's effectiveness as part of a broader attack but did not enable a direct attack on customers	[61][62][67]	Confirmed

Case	What the vendor said happened	What was taken	Product or code compromised?	Source	Grade
Bit9, 2013	Through an operational oversight Bit9 had not installed its own product on a handful of machines; initial access in July 2012 through SQL injection on an Internet-facing web server; malware included Hikit (S0009) and a Hydraq (S0203) dropper	A code-signing certificate, used to sign 32 files delivered through watering-hole sites and a Java exploit; three customers affected	Bit9 said its product was not compromised	[64][65][67]	Confirmed
Kaspersky, 2015	Duqu 2.0, an advanced attack on the internal network using several zero-days, one fixed as MS15-061; a nation state very likely behind it, none named	Information on Kaspersky technologies and investigations	Kaspersky said products, source code and customer data were not compromised; the Duqu family, including Duqu 2.0 in Kaspersky's network, is recorded in Stuxnet: The Case Study	[66]	Confirmed
FireEye, 2020	Highly sophisticated, believed state-sponsored attack through trojanized Orion updates	Red Team assessment tools; information on certain government customers was sought	No evidence of exfiltration from primary customer-data systems	[1][25]	Confirmed

EMC recorded a $66.3 million Q2 2011 charge to expand SecurID customer remediation, with an $81.3 million reserve at 30 June 2011 (Confirmed [63]). In each case the vendor drew a line around what was not affected: RSA said the theft did not enable a direct attack on customers, Bit9 that its product was not compromised, Kaspersky that products, source code and customer data were not compromised, and FireEye that it saw no exfiltration from its primary customer-data systems (Confirmed [61][64][66][1]). What was taken differed: SecurID-related information, a signing certificate, research and detection knowledge, and red team tools (Inferred [61][64][66][1]). Two of the three earlier cases turned on trust material, SecurID-related information and a code-signing key, which is the same class of asset the 2020 campaign pursued with AD FS token-signing certificates (Inferred [61][65][23]).

Part 8: the vulnerability-management view

FireEye's CVEs_red_team_tools.md gives a ranked list of 16 CVEs to patch to limit the tools' effectiveness, committed on 8 December 2020 at 22:36:26 UTC (Confirmed [8]). The ranking, product names where the record names them, KEV status and the CWE KEV lists are below. KEV fields were read from the catalog feed on 11 November 2026 (Confirmed [9]).

Rank	CVE	Product (where the opened record names it)	KEV added	Known ransomware use (KEV)	CWE (KEV)	Source
1	CVE-2019-11510	Pulse Secure	2021-11-03	Known	CWE-22	[8][9][54]
2	CVE-2020-1472	Netlogon	2021-11-03	Known	CWE-330 (NVD: NVD-CWE-noinfo)	[8][9][54]
3	CVE-2018-13379	FortiOS SSL VPN	2021-11-03	Known	CWE-22	[8][9][54]
4	CVE-2018-15961	ColdFusion	2021-11-03	Unknown	CWE-434	[8][9]

Rank	CVE	Product (where the opened record names it)	KEV added	Known ransomware use (KEV)	CWE (KEV)	Source
5	CVE-2019-0604	SharePoint	2021-11-03	Known	CWE-20	[8][9]
6	CVE-2019-0708	Remote Desktop Services	2021-11-03	Known	CWE-416	[8][9]
7	CVE-2019-11580	See the KEV entry	2021-11-03	Known	None listed	[8][9]
8	CVE-2019-19781	Citrix	2021-11-03	Known	CWE-22	[8][9][54]
9	CVE-2020-10189	See the KEV entry	2021-11-03	Unknown	CWE-502	[8][9]
10	CVE-2014-1812	See the KEV entry	2021-11-03	Known	CWE-255	[8][9]
11	CVE-2019-3398	See the KEV entry	2021-11-03	Unknown	CWE-22	[8][9]
12	CVE-2020-0688	See the KEV entry	2021-11-03	Known	CWE-287	[8][9]
13	CVE-2016-0167	See the KEV entry	2021-11-03	Known	CWE-264	[8][9]
14	CVE-2017-11774	See the KEV entry	2021-11-03	Unknown	CWE-119	[8][9]
15	CVE-2018-8581	See the KEV entry	2022-03-03	Known	None listed	[8][9]
16	CVE-2019-8394	See the KEV entry	2021-11-03	Unknown	CWE-434	[8][9]

What the table shows:

- **Every CVE was known and fixed before the theft was disclosed.** Each had a public record and a vendor fix before 8 December 2020, which fits FireEye's statement that the tools held no zero-days (Inferred [8][1]).
- **Fifteen of the 16 entered KEV on its first day.** The catalog opened on 3 November 2021 with 15 of them; CVE-2018-8581 followed on 3 March 2022 (Confirmed [9]).
- **Most are ransomware-relevant.** KEV marks known ransomware campaign use for 11 of the 16 and Unknown for five: CVE-2018-15961, CVE-2020-10189, CVE-2019-3398, CVE-2017-11774 and CVE-2019-8394 (Confirmed [9]). The wider record of edge-device exploitation by ransomware crews is in The Ransomware Ecosystem, 2019 to 2026.
- **The CWE record disagrees in one place.** KEV lists CWE-330 for CVE-2020-1472, while NVD lists NVD-CWE-noinfo (Confirmed [9][54]). For CVE-2019-11510, CVE-2018-13379 and CVE-2019-19781, NVD and KEV agree on CWE-22 (Confirmed [54][9]). The NVD pages for the other twelve were not opened.
- **Remote-access flaws lead the list.** The top three are two VPN flaws and Netlogon, and three of FireEye's 16 also appear in the April 2021 SVR advisory (Confirmed [8][28]; Inferred for the observation).

The two CVE lists in this record are different claims: FireEye's list is what its stolen tools could exploit; the April 2021 joint advisory lists what SVR actors were seen exploiting (Inferred [8][28]). For CVE-2020-0688, Volexity also reports the Dark Halo actor exploiting it in a separate intrusion (Confirmed [38]). See the CVE Reference and Vulnerability Management Reference.

Part 9: the defender view

The identity plane caught it

The intrusion was first identified through an identity alert, a second phone registered for an employee's two-factor codes (Confirmed [11]). Mapping the second-phone registration to ATT&CK T1098.005 Device Registration, which covers enrolling a new device to bypass MFA after a credential compromise, is this study's inference: ATT&CK's T1098.005 procedures cite APT29 cloud-tenant device enrollment and C0024 mailbox-sync device registration, and neither names FireEye (Inferred [34][32]). Mandiant's merge report lists APT29 methods from 2018 to 2020 that include enrolling devices for MFA or bypassing MFA through legacy authentication, precomputed cookies and repeated push notifications, without tying them to the FireEye intrusion (Confirmed [31]).

The rest of the campaign shows how MFA was bypassed elsewhere. Volexity's Dark Halo actor, holding a valid password, was never challenged for a second factor because it had the MFA integration secret from the Outlook Web App server; Volexity says this was not a vulnerability in the MFA provider (Confirmed [38]). CrowdStrike reports the StellarParticle actor bypassing MFA by stealing Chrome browser cookies, hijacking Office 365 service principals and using different credentials for each lateral step (Confirmed [39]). Mandiant notes that forged tokens bypass the user's MFA altogether (Confirmed [23]).

The cloud follow-on

Microsoft warned on 14 December 2020 that an actor with on-premises admin access can obtain the SAML token-signing certificate and forge tokens that impersonate any existing user, and that the actor added credentials to existing OAuth applications and service principals to read mail (Confirmed [36]). CISA's AA21-008A describes forged authentication tokens, credentials added to service principals and on-premises access used to manipulate and bypass identity controls and MFA; it assigns no ATT&CK id to SAML forgery (Confirmed [37]). Mandiant's 19 January 2021 paper lists the UNC2452 moves from on-premises into Microsoft 365: theft of the AD FS token-signing certificate to forge tokens, adding a federated identity provider through trusted-domain changes, compromising synced on-premises accounts with high-privilege roles, adding credentials to existing applications and service principals, and changing mailbox folder permissions (Confirmed [23]). Its detection table prints a sub-technique number that ATT&CK does not have next to a link to T1098/001, so the printed id and the link do not match; this study uses T1098.001, the id the link and the procedure text point to (Confirmed [23]; Inferred for the choice).

Detection ideas that still hold

FireEye's SUNBURST report lists hunting opportunities at the level of behavior (Confirmed [15]):

- Attacker hostnames matched victim hostnames and leaked in RDP certificates.
- Attacker IP addresses were VPS addresses in the victim's own country, so impossible-travel and ASN baselines apply.
- Lateral movement used different credentials from those used for remote access.
- Files were replaced temporarily, in a delete-create-execute pattern over SMB, and scheduled tasks were modified temporarily.

Mandiant's Microsoft 365 paper names detections for risky sign-ins, new or changed domain federation, credentials added to service principals, access to the AD FS DKM container and suspicious folder-permission

changes, and notes that many of these techniques are dual-use (Confirmed [23]). CISA's AA21-008A offers the Sparrow, Hawk and CrowdStrike CRT tools, recommends MailItemsAccessed review, and says domain and federation modifications are uncommon and should be investigated (Confirmed [37]). Mandiant's Azure AD Investigator, a read-only PowerShell module, flags federation signing certificates valid for more than one year, issuer and subject mismatches, the any.sts issuer URI left by an AADInternals (S0677) backdoor, unverified domains, and first-party service principals with added credentials (Confirmed [24]; Demonstrated [68] for S0677).

Recovery

Microsoft's recovery guidance says the highest-assurance fix for a token-signing compromise is to remove the federation trust and move to cloud-mastered identity; a single certificate rotation leaves the old certificate valid during a grace period; krbtgt should be reset twice; service-principal credentials should be audited; and MFA should be enforced for all elevated users (Confirmed [41]). These map to the D3FEND countermeasures in Part 10.

The same techniques, four years on

Year	Record	Identity technique	Source	Grade
2020	FireEye detection	Second phone registered for two-factor codes	[11]	Confirmed
2019 to 2021	ATT&CK C0024	Device registration for mailbox sync; federation trust changes; credentials on OAuth apps and service principals	[32]	Confirmed
2022	Mandiant	APT29 disabled Purview Audit on targeted accounts, password-guessed a dormant mailbox, self-enrolled MFA on it and used it on Azure AD-backed VPN; Azure VMs for last-mile access	[45]	Confirmed
2024	Microsoft	Midnight Blizzard password-sprayed a legacy non-production test tenant account with no MFA, took over a legacy OAuth app, granted it full_access_as_app and read corporate mail through EWS behind residential proxies	[47]	Confirmed
2024	AA24-057A (NCSC with NSA, CISA, CNMF, FBI, ASD ACSC, CCCS, GCSB)	Password spraying, service and dormant accounts, token theft, MFA bombing, registering its own devices, residential proxies	[46]	Confirmed

These identity-plane techniques outlasted the Orion campaign (Inferred [32][45][46][47]). Mandiant's 2022 recommendation follows directly: every active account should have an MFA device, with conditional access on MFA registration (Confirmed [45]).

Part 10: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CAPEC, CWE and D3FEND. Every id was checked against the live MITRE page or the library's data files on 11 November 2026, and every linked page exists in the library's mitre/ tree at main 4be984e7 (Confirmed [32][33][34][67]; Demonstrated [68]). The record touches no industrial systems, so there is no ATT&CK for ICS table (Inferred).

ATT&CK Enterprise techniques

The table holds the techniques the opened record supports for the FireEye intrusion and the campaign that delivered it. FireEye's own 13 December post maps T1195.002, T1553.002, T1568.002, T1071.001, T1071.004, T1132.001, T1027, T1070.004, T1105, T1543.003, T1569.002, T1518, T1518.001, T1057, T1083, T1012 and T1584 (Confirmed [15]). AA20-352A lists T1195.001, T1195.002 and T1027.003 (Confirmed [20]). C0024 procedure text supports the cloud and identity techniques (Confirmed [32]). AA24-057A adds the 2024 identity ids (Confirmed [46]). Tactic names follow the library's v20.0 technique profiles, where the former Defense Evasion tactic is split into Stealth and Defense Impairment (Demonstrated [68]). T1528 and T1621 are not on C0024 in the library data; both are on G0016 (Demonstrated [68]; Confirmed [33]). T1556.006 is not listed for APT29 and is left out (Confirmed [33]).

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1195.002	Compromise Software Supply Chain	Initial Access	FireEye's 10-K: access through trojanized Orion updates (26 Feb 2021); FireEye technique list (13 Dec 2020); C0024; AA20-352A	[25][15][32][20]
T1195.001	Compromise Software Dependencies and Development Tools	Initial Access	AA20-352A technique list (17 Dec 2020)	[20]
T1199	Trusted Relationship	Initial Access	C0024 procedure (campaign Aug 2019 to Jan 2021)	[32]
T1133	External Remote Services	Persistence, Initial Access	C0024 procedure	[32]
T1078.004	Cloud Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Synced privileged accounts (Mandiant, 19 Jan 2021); C0024; AA24-057A (26 Feb 2024)	[23][32][46]
T1098.005	Device Registration	Persistence, Privilege Escalation	FireEye's late-November 2020 second-phone alert (this study's mapping, Inferred); C0024 mailbox-sync registration; AA24-057A (2024)	[11][34][32][46]
T1098.001	Additional Cloud Credentials	Persistence, Privilege Escalation	Credentials added to OAuth apps and service principals (MSRC, Dec 2020; Mandiant, Jan 2021; AA21-008A); C0024	[36][23][37][32]
T1098.002	Additional Email Delegate Permissions	Persistence, Privilege Escalation	Mailbox folder permission changes (Mandiant, 19 Jan 2021); C0024	[23][32]
T1543.003	Windows Service	Persistence, Privilege Escalation	FireEye technique list (13 Dec 2020)	[15]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	Temporary scheduled-task modification (FireEye, 13 Dec 2020); C0024	[15][32]
T1569.002	Service Execution	Execution	FireEye technique list (13 Dec 2020)	[15]
T1553.002	Code Signing	Defense Impairment	Trojanized DLL signed 24 Mar 2020 (FireEye, 13 Dec 2020); C0024	[15][32]
T1484.002	Trust Modification	Defense Impairment, Privilege Escalation	Trusted-domain changes adding an attacker identity provider (Mandiant, 19 Jan 2021; AA21-008A); C0024	[23][37][32]

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1027	Obfuscated Files or Information	Stealth	FireEye technique list (13 Dec 2020)	[15]
T1027.003	Steganography	Stealth	AA20-352A, citing FireEye's report and noting CISA had not independently confirmed it (17 Dec 2020)	[20]
T1036.005	Match Legitimate Resource Name or Location	Stealth	C0024 procedure	[32]
T1070.004	File Deletion	Stealth	FireEye technique list (13 Dec 2020); C0024	[15][32]
T1003.006	DCSync	Credential Access	C0024 procedure	[32]
T1552.004	Private Keys	Credential Access	AD FS token-signing certificate theft (Mandiant, 19 Jan 2021); C0024	[23][32]
T1606.002	SAML Tokens	Credential Access	Forged SAML tokens (MSRC, Dec 2020; AA21-008A, 8 Jan 2021; Mandiant, 19 Jan 2021); C0024; not seen inside FireEye in the opened record	[36][37][23][32]
T1606.001	Web Cookies	Credential Access	C0024 procedure	[32]
T1539	Steal Web Session Cookie	Credential Access	Chrome cookie theft to bypass MFA (CrowdStrike, 27 Jan 2022); C0024	[39][32]
T1110	Brute Force	Credential Access	Password guessing and spraying (AA20-352A; AA21-116A); AA24-057A id (2024)	[20][30][46]
T1528	Steal Application Access Token	Credential Access	AA24-057A token theft (26 Feb 2024); not on C0024	[46][68]
T1621	Multi-Factor Authentication Request Generation	Credential Access	On G0016; MFA bombing in AA24-057A (26 Feb 2024)	[33][46]
T1012	Query Registry	Discovery	FireEye technique list (13 Dec 2020)	[15]
T1057	Process Discovery	Discovery	FireEye technique list (13 Dec 2020)	[15]
T1083	File and Directory Discovery	Discovery	FireEye technique list (13 Dec 2020)	[15]
T1518	Software Discovery	Discovery	FireEye technique list (13 Dec 2020)	[15]
T1518.001	Security Software Discovery	Discovery	FireEye technique list (13 Dec 2020)	[15]
T1021.001	Remote Desktop Protocol	Lateral Movement	C0024; attacker hostnames leaked in RDP certificates (FireEye, 13 Dec 2020)	[32][15]
T1550.001	Application Access Token	Lateral Movement	C0024 procedure	[32]
T1550.004	Web Session Cookie	Lateral Movement	C0024 procedure	[32]
T1114.002	Remote Email Collection	Collection	C0024; Mandia: the attackers moved into Office 365 to target email (23 Feb 2021)	[32][12]

Id	Name	Tactic (v20.0)	Where it appears in the record	Source
T1071.001	Web Protocols	Command and Control	FireEye technique list (13 Dec 2020)	[15]
T1071.004	DNS	Command and Control	FireEye technique list (13 Dec 2020)	[15]
T1132.001	Standard Encoding	Command and Control	FireEye technique list (13 Dec 2020)	[15]
T1568.002	Domain Generation Algorithms	Command and Control	DGA-based C2 (FireEye, 13 Dec 2020)	[15]
T1105	Ingress Tool Transfer	Command and Control	FireEye technique list (13 Dec 2020)	[15]
T1090.002	External Proxy	Command and Control	Residential proxies (AA24-057A, 26 Feb 2024)	[46]
T1584	Compromise Infrastructure	Resource Development	FireEye technique list (13 Dec 2020)	[15]

ATT&CK groups, software and campaigns

Object	Id	Role in the record	Source
APT29	G0016	The group UNC2452 was merged into; attributed to the SVR; aliases include UNC2452, NOBELIUM, Dark Halo, SolarStorm and Midnight Blizzard	[33][31][68]
SolarWinds Compromise	C0024	The campaign that delivered the FireEye intrusion; Aug 2019 to Jan 2021; v1.1 modified 31 Jul 2026; industry names UNC2452, NOBELIUM, StellarParticle, Dark Halo and SolarStorm. Whether C0024 cites the FireEye breach itself was not checked	[32][67]
SUNBURST	S0559	The Orion backdoor FireEye found on its own server	[15][32]
TEARDROP	S0560	Memory-only dropper deploying Cobalt Strike BEACON	[15][32]
Cobalt Strike	S0154	BEACON payload of the campaign; also a rule family (BEACON profiles) in FireEye's countermeasures	[15][7][67]
SUNSPOT, Raindrop	S0562, S0565	SUNSPOT, the build implant (CrowdStrike), and Raindrop, both C0024 software; detail in the home study	[32][19]
AdFind, Mimikatz, TrailBlazer	S0552, S0002, S0682	Other C0024 software	[32]
GoldMax, GoldFinder, Sibot	S0588, S0597, S0589	NOBELIUM malware Microsoft described on 4 Mar 2021	[40][32]
AADInternals	S0677	The tool whose federation backdoor leaves the any.sts issuer URI that Azure AD Investigator flags	[24][68]
Rubeus, Impacket, BloodHound	S1071, S0357, S0521	Public tool families covered by FireEye's countermeasures (RUBEUS, IMPACKETOBF, PUPPYHOUND with a SharpHound rule); their presence in the stolen kit is Inferred, not stated by FireEye	[7][67]
PoisonIvy	S0012	The RSA 2011 comparison case	[62][67]
Hikit, Hydraq	S0009, S0203	The Bit9 2013 comparison case	[65][67]
Duqu	S0038	ATT&CK's Duqu record; Kaspersky's 2015 breach was by Duqu 2.0, and whether S0038 covers Duqu 2.0 was not checked	[66][67]

The library's groups data carries UNC2452 only as an alias of APT29, with no separate group record, so only G0016 is linked (Demonstrated [68]).

CAPEC and CWE

Id	Name	Fit to this record	Source	Grade
CAPEC-678	System Build Data Maliciously Altered	Library maps it to T1195.002; describes the Orion build compromise that delivered the intrusion	[68][18]	Demonstrated for the mapping; Inferred for the fit
CAPEC-673	Developer Signing Maliciously Altered Software	Library maps it to T1195.002; the trojanized DLL was signed by the vendor	[68][15]	Demonstrated for the mapping; Inferred for the fit
CAPEC-511	Infiltration of Software Development Environment	Library maps it to T1195.001, which AA20-352A lists	[68][20]	Demonstrated for the mapping; Inferred for the fit
CAPEC-206	Signing Malicious Code	One of the library's three CAPEC mappings for T1553.002	[68][15]	Demonstrated for the mapping; Inferred for the fit
CAPEC-474	Signature Spoofing by Key Theft	Library maps it to T1552.004; fits theft of the AD FS token-signing key used to forge tokens	[68][23]	Demonstrated for the mapping; Inferred for the fit
CAPEC-21	Exploitation of Trusted Identifiers	Library maps it to T1528 and T1539; fits cookie and token theft	[68][39][46]	Demonstrated for the mapping; Inferred for the fit
CAPEC-60	Reusing Session IDs (aka Session Replay)	Library maps it to T1550.004	[68][32]	Demonstrated for the mapping; Inferred for the fit
CAPEC-112	Brute Force	Library maps it to T1110; password spraying	[68][30]	Demonstrated for the mapping; Inferred for the fit
CAPEC-555	Remote Services with Stolen Credentials	Library maps it to T1114.002 and T1133	[68][32]	Demonstrated for the mapping; Inferred for the fit

The intrusion itself carries no CVE and no CWE in the primary record (Inferred [1][25]). The CWE ids in this study belong to the 16 CVEs FireEye listed, as KEV records them (Confirmed [9]):

CWE	Name (library data)	CVEs on FireEye's list	Source
CWE-22	Improper Limitation of a Pathname to a Restricted Directory	CVE-2019-11510, CVE-2018-13379, CVE-2019-19781, CVE-2019-3398	[9][54][68]
CWE-330	Use of Insufficiently Random Values	CVE-2020-1472 (NVD lists NVD-CWE-noinfo)	[9][54][68]
CWE-434	Unrestricted Upload of File with Dangerous Type	CVE-2018-15961, CVE-2019-8394	[9][68]
CWE-20	Improper Input Validation	CVE-2019-0604	[9][68]
CWE-416	Use After Free	CVE-2019-0708	[9][68]
CWE-502	Deserialization of Untrusted Data	CVE-2020-10189	[9][68]
CWE-287	Improper Authentication	CVE-2020-0688	[9][68]

CWE	Name (library data)	CVEs on FireEye's list	Source
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	CVE-2017-11774	[9][68]
CWE-255	Not in the library's CWE data (a category id)	CVE-2014-1812	[9][68]
CWE-264	Not in the library's CWE data (a category id)	CVE-2016-0167	[9][68]

KEV lists no CWE for CVE-2019-11580 or CVE-2018-8581 (Confirmed [9]). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

The library's `technique_to_d3fend.jsonl` has no rows for T1606.002, T1484.002, T1098.005 or T1552.004, only for their parents T1606, T1484, T1098 and T1552 (Demonstrated [68]). The countermeasures below are the library's named mappings to this study's techniques, plus one, Certificate Rotation, that matches the guidance in the record but has no library mapping to these techniques (Demonstrated [68]):

Countermeasure	Id	Library mapping to this study's techniques	Guidance in the record it matches	Source
Multi-factor Authentication	D3-MFA	T1098.001, T1528, T1539, T1550.001, T1550.004, T1606.001	MFA device on every active account (Mandiant, 2022); note that forged tokens bypass MFA, so MFA alone does not counter Golden SAML	[68][45][23]
Credential Rotation	D3-CRO	Same set	Reset krbtgt twice	[68][41]
Credential Revocation	D3-CR	Same set	Remove credentials added to service principals	[68][41][37]
Authentication Cache Invalidation	D3-ANCI	Same set	Invalidate forged or stolen sessions and tokens	[68][41]
Reissue Credential	D3-RIC	Same set	Reissue credentials after a systemic identity compromise	[68][41]
Credential Hardening	D3-CH	Same set	Enforce MFA for all elevated users	[68][41]
Credential Compromise Scope Analysis	D3-CCSA	Same set	MailItemsAccessed review to scope mail access	[68][37]
Access Modeling	D3-AM	T1078.004, T1098.002	Know which synced on-premises accounts hold cloud admin roles	[68][23]
User Account Permissions	D3-UAP	T1078.004, T1098.002	Remove high-privilege roles from synced accounts	[68][23]
Domain Account Monitoring	D3-DAM	T1098.002	Alert on suspicious mailbox folder-permission changes	[68][23]
User Geolocation Logon Pattern Analysis	D3-UGLPA	T1003.006, T1021.001, T1071.001, T1071.004, T1090.002, T1098.001, T1105, T1199, T1550.001, T1550.004	Impossible travel and in-country VPS baselines	[68][15]

Countermeasure	Id	Library mapping to this study's techniques	Guidance in the record it matches	Source
Remote Terminal Session Detection	D3-RTSD	Same set	Attacker hostnames leaked in RDP certificates	[68][15]
Session Termination	D3-ST	T1021.001, T1133, T1199	End sessions of compromised partner or cloud accounts (Inferred pairing)	[68]
Token Binding	D3-TB	T1528, T1550.001	Limits replay of stolen application tokens (Inferred pairing)	[68]
Process Lineage Analysis	D3-PLA	T1053.005, T1621	One of the library's 12 mappings for MFA request generation, all process- or session-level; the record's own advice is conditional access on MFA registration, so the fit is weak (Inferred)	[68][45]
Web Session Access Mediation	D3-WSAM	T1621	Of the library's 12 mappings for MFA request generation, the closest to the record's advice: mediate session access with authentication and integrity checks (Inferred pairing)	[68][45]
Certificate Rotation	D3-CERO	No library mapping to these techniques	Rotate the token-signing certificate with care; one rotation leaves the old one valid	[68][41]
Certificate Analysis	D3-CA	T1071.001	Azure AD Investigator's long-validity and issuer-mismatch checks	[68][24]
Configuration Inventory	D3-CI	T1518.001	Inventory federation and trusted-domain settings to spot added identity providers	[68][23]
Restore Configuration	D3-RC	T1518.001	Remove the attacker's federation trust; move to cloud-mastered identity	[68][41]
File Integrity Monitoring	D3-FIM	T1036.005, T1070.004, T1071.001, T1083	Catch temporary replacement of legitimate files	[68][15]

The countermeasures that matter most here, protecting the token-signing key and alerting on federation changes and new MFA devices, have no direct D3FEND binding in the library today for T1552.004, T1484.002 or T1098.005 (Demonstrated [68]; Inferred for the gap).

Navigator layer

The study's Enterprise techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/mandiant-intrusion-2020.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 (navigator 4.9, layer format 4.5) and holds every technique of the table above, each shown under every tactic in its library technique profile. Scores mark membership only. Each entry's comment names the source numbers of this study's Sources table.

Cross-cutting themes

- **The victim was also the first responder.** FireEye's breach turned into the public discovery of SUNBURST because an incident-response company investigated itself and published what it found (Confirmed [11][15]; Inferred for the framing). Compare the SolarWinds study's point that disclosure came from a victim, not a control.

- **Identity is the perimeter that caught it and the one that was crossed.** A device-registration alert raised the flag; tokens, federation trusts and application credentials carried the campaign into cloud mail (Confirmed [11][23][36]). See Identity Security, Active Directory Attacks and Cloud Attack Reference.
- **Security vendors hold trust material.** RSA's SecurID-related data, Bit9's signing certificate, Kaspersky's research and FireEye's tools were each valuable because of what others trusted them to do (Confirmed [61][64][66][1]; Inferred for the pattern). See Certificate Trust Incident Response.
- **Offensive tooling is mostly public tooling.** FireEye's stolen kit was largely public or lightly modified, and the most effective mitigation was patching known CVEs (Confirmed [3][8]). See the Red Team Reference.
- **Attribution has a vocabulary.** "State-sponsored", "likely Russian", "highly likely" and "high confidence" are different claims (Confirmed [1][22][29][26]). See Threat Actors and Russia-Attributed Threat Actors.
- **Transparency became policy.** Mandia's call for confidential, non-punitive breach reporting, EO 14028's sharing provisions and the SEC's 2024 disclosure cases sit on one line (Confirmed [11][43][44]; Inferred for the line).

What is overstated and what is understated

- **Overstated: the tool theft.** The tools held no zero-days, many were public or in CommandoVM, no use had been seen through February 2021, and the main mitigation was patching 16 already-public CVEs (Confirmed [1][3][8][11]). No later primary source showing in-the-wild use was found (not checked beyond the sources listed).
- **Overstated: the tools as the target.** The 8-K's own emphasis was that the attacker primarily sought information on certain government customers (Confirmed [1]); the tools were the visible loss, not the stated objective (Inferred).
- **Not supported: the sale as fallout.** Reading the 2021 products sale as a consequence of the breach finds no support in the opened record: the divestment was explored from 2019 and the merger proxy does not tie it to the intrusion (Confirmed [51]).
- **Understated: the identity plane.** An MFA device-registration alert caught the intrusion, and federation, SAML and service-principal techniques recur through 2024 (Confirmed [11][23][45][46][47]; Inferred for the synthesis).
- **Understated: the speed of the defensive release.** The repository existed five days before disclosure, and rules, a ranked CVE list and partner sharing went out on day one (Demonstrated [4]; Confirmed [3][8]).
- **Understated: the count disagreement.** More than 300, hundreds, 324 and more than 500 are all in the company's own record; a single number hides that the sets differ (Confirmed [1][3][11]; Demonstrated [6]).

Sources

All sources were opened on 11 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here. Addresses shown as code rather than as links refuse automated link checkers: the sec.gov filings and the SEC press release; copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	FireEye, Form 8-K (Item 8.01), 8 Dec 2020	https://www.sec.gov/Archives/edgar/data/1370880/000137088020000037/feye-20201208.htm	2026-11-11	Confirmed
2	FireEye (Kevin Mandia), FireEye shares details of recent cyber attack, actions to protect community, 8 Dec 2020 (Wayback capture of 1 Jan 2021; the original URL now redirects)	web.archive.org/web/20210101045246id_/https://www.fireeye.com/blog/...	2026-11-11	Confirmed
3	FireEye (Google Cloud blog), Unauthorized Access of FireEye Red Team Tools, 8 Dec 2020	cloud.google.com/blog/topics/threat-intelligence/unauthorized-access-of-fireeye-red-team-tools	2026-11-11	Confirmed
4	Mandiant (FireEye), red_team_tool_countermeasures repository and README (creation, commit and archive metadata)	github.com/mandiant/red_team_tool_countermeasures	2026-11-11	Confirmed; Demonstrated for metadata
5	Same repository, signatures table of contents at commit b39b169, 8 Dec 2020	github.com/mandiant/red_team_tool_countermeasures/blob/b39b169.../signatures_table_of_content.csv	2026-11-11	Demonstrated
6	Same repository, signatures table of contents at master (commit 1b90ba7, 30 Dec 2020)	github.com/mandiant/red_team_tool_countermeasures/blob/master/signatures_table_of_content.csv	2026-11-11	Demonstrated
7	Same repository, rules folder	github.com/mandiant/red_team_tool_countermeasures/tree/master/rules	2026-11-11	Confirmed
8	Same repository, CVEs_red_team_tools.md, committed 8 Dec 2020	github.com/mandiant/red_team_tool_countermeasures/blob/master/CVEs_red_team_tools.md	2026-11-11	Confirmed
9	CISA, Known Exploited Vulnerabilities catalog (JSON feed)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
10	CISA, alert: Theft of FireEye Red Team Tools, 8 Dec 2020	cisa.gov/news-events/alerts/2020/12/08/theft-fireeye-red-team-tools	2026-11-11	Confirmed
11	Kevin Mandia, prepared statement, Senate Select Committee on Intelligence, 23 Feb 2021	intelligence.senate.gov/wp-content/uploads/2024/08/sites-default-files-documents-os-kmandia-022321.pdf	2026-11-11	Confirmed
12	Senate Select Committee on Intelligence, hearing transcript S. Hrg. 117 (CHRG-117shrg45485), 23 Feb 2021	govinfo.gov/content/pkg/CHRG-117shrg45485/html/CHRG-117shrg45485.htm	2026-11-11	Confirmed
13	House Oversight and Homeland Security, "Weathering the Storm" hearing transcript (CHRG-117hhrg43755), 26 Feb 2021	govinfo.gov/content/pkg/CHRG-117hhrg43755/html/CHRG-117hhrg43755.htm	2026-11-11	Confirmed
14	FireEye, Form 8-K filed 14 Dec 2020 (event 13 Dec 2020)	https://www.sec.gov/Archives/edgar/data/1370880/000137088020000039/feye-20201213.htm	2026-11-11	Confirmed
15	FireEye (Google Cloud blog), the SUNBURST report on a highly evasive attacker using the SolarWinds supply chain against multiple global victims, 13 Dec 2020, with May 2022 update	cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
16	Mandiant (FireEye), sunburst_countermeasures repository	github.com/mandiant/sunburst_countermeasures	2026-11-11	Confirmed; Demonstrated for metadata and counts
17	FireEye (Google Cloud blog), SUNBURST additional technical details, 24 Dec 2020	cloud.google.com/blog/topics/threat-intelligence/sunburst-additional-technical-details	2026-11-11	Confirmed
18	SolarWinds, new findings from our investigation of SUNBURST	solarwinds.com/blog/new-findings-from-our-investigation-of-sunburst	2026-11-11	Confirmed
19	CrowdStrike, SUNSPOT malware technical analysis, 11 Jan 2021	crowdstrike.com/blog/sunspot-malware-technical-analysis	2026-11-11	Confirmed
20	CISA, AA20-352A, first published 17 Dec 2020, revised 15 Apr 2021	cisa.gov/news-events/cybersecurity-advisories/aa20-352a	2026-11-11	Confirmed
21	CISA, Emergency Directive 21-01 (sunset)	cisa.gov/news-events/directives/ed-21-01-mitigate-solarwinds-orion-code-compromise	2026-11-11	Confirmed
22	FBI, CISA, ODNI and NSA, joint statement, 5 Jan 2021	cisa.gov/news/2021/01/05/joint-statement-...	2026-11-11	Confirmed
23	Mandiant (Google Cloud blog), Remediation and hardening strategies for Microsoft 365 to defend against UNC2452, 19 Jan 2021, updated Mar and Oct 2021 and May 2022	cloud.google.com/blog/topics/threat-intelligence/remediation-and-hardening-strategies-...	2026-11-11	Confirmed
24	Mandiant, Mandiant-Azure-AD-Investigator repository, created 13 Jan 2021	github.com/mandiant/Mandiant-Azure-AD-Investigator	2026-11-11	Confirmed
25	FireEye, Form 10-K for fiscal 2020 (26 Feb 2021)	`https://www.sec.gov/Archives/edgar/data/1370880/000137088021000010/feye-20201231.htm`	2026-11-11	Confirmed
26	The White House, fact sheet: imposing costs for harmful foreign activities by the Russian government, 15 Apr 2021	bidenwhitehouse.archives.gov/briefing-room/statements-releases/2021/04/15/...	2026-11-11	Confirmed
27	US Treasury, press release jy0127, 15 Apr 2021	home.treasury.gov/news/press-releases/jy0127	2026-11-11	Confirmed
28	CISA, NSA-CISA-FBI joint advisory on Russian SVR targeting US and allied networks (summary page), 15 Apr 2021; the NSA PDF was not opened	cisa.gov/news-events/alerts/2021/04/15/...	2026-11-11	Confirmed
29	UK NCSC, UK and US call out Russia for SolarWinds compromise, 15 Apr 2021	ncsc.gov.uk/news/uk-and-us-call-out-russia-for-solarwinds-compromise	2026-11-11	Confirmed
30	CISA, FBI and DHS, AA21-116A, 26 Apr 2021	cisa.gov/news-events/cybersecurity-advisories/aa21-116a	2026-11-11	Confirmed
31	Mandiant (Google Cloud blog), Assembling the Russian Nesting Doll: UNC2452 merged into APT29, 27 Apr 2022	cloud.google.com/blog/topics/threat-intelligence/unc2452-merged-into-apt29	2026-11-11	Confirmed
32	MITRE ATT&CK, campaign C0024 SolarWinds Compromise, v1.1 (modified 31 Jul 2026)	attack.mitre.org/campaigns/C0024	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
33	MITRE ATT&CK, group G0016 APT29	attack.mitre.org/groups/G0016	2026-11-11	Confirmed
34	MITRE ATT&CK, T1098.005 Device Registration	attack.mitre.org/techniques/T1098/005	2026-11-11	Confirmed
35	Palo Alto Networks Unit 42, SolarStorm supply-chain attack timeline, 23 Dec 2020	unit42.paloaltonetworks.com/solarstorm-supply-chain-attack-timeline	2026-11-11	Confirmed
36	Microsoft MSRC, customer guidance on recent nation-state cyber attacks, Dec 2020	microsoft.com/en-us/msrc/blog/2020/12/customer-guidance-on-recent-nation-state-cyber-attacks	2026-11-11	Confirmed
37	CISA, AA21-008A, 8 Jan 2021, revised 15 Apr 2021	cisa.gov/news-events/cybersecurity-advisories/aa21-008a	2026-11-11	Confirmed
38	Volexity, Dark Halo report on breaches through the SolarWinds compromise, 14 Dec 2020	volexity.com/blog/2020/12/14/dark-halo-...	2026-11-11	Confirmed
39	CrowdStrike, observations from the StellarParticle campaign, 27 Jan 2022	crowdstrike.com/blog/observations-from-the-stellarparticle-campaign	2026-11-11	Confirmed
40	Microsoft, GoldMax, GoldFinder and Sibot: analyzing NOBELIUM's layered persistence, 4 Mar 2021	microsoft.com/en-us/security/blog/2021/03/04/goldmax-goldfinder-sibot-analyzing-nobelium-malware	2026-11-11	Confirmed
41	Microsoft, advice for incident responders on recovery from systemic identity compromises, 21 Dec 2020	microsoft.com/en-us/security/blog/2020/12/21/...	2026-11-11	Confirmed
42	Microsoft MSRC, Microsoft internal Solorigate investigation update, 31 Dec 2020	microsoft.com/en-us/msrc/blog/2020/12/microsoft-internal-solorigate-investigation-update	2026-11-11	Confirmed
43	Executive Order 14028, 12 May 2021 (Federal Register, 17 May 2021)	govinfo.gov/content/pkg/FR-2021-05-17/pdf/2021-10460.pdf	2026-11-11	Confirmed
44	SEC, press release 2024-174, 22 Oct 2024	https://www.sec.gov/newsroom/press-releases/2024-174	2026-11-11	Confirmed
45	Mandiant (Google Cloud blog), APT29 continues targeting Microsoft, 18 Aug 2022	cloud.google.com/blog/topics/threat-intelligence/apt29-continues-targeting-microsoft	2026-11-11	Confirmed
46	NCSC, NSA, CISA and partners, AA24-057A, SVR cyber actors adapt tactics for initial cloud access, 26 Feb 2024	cisa.gov/news-events/cybersecurity-advisories/aa24-057a	2026-11-11	Confirmed
47	Microsoft, Midnight Blizzard: guidance for responders on nation-state attack, 25 Jan 2024	microsoft.com/en-us/security/blog/2024/01/25/...	2026-11-11	Confirmed
48	FireEye, Form 8-K filed 2 Jun 2021 (products business sale agreement of 29 May 2021)	https://www.sec.gov/Archives/edgar/data/1370880/000110465921075725/tm2118082d1_8k.htm	2026-11-11	Confirmed
49	FireEye, Form 8-K on the name change to Mandiant, Inc., Oct 2021	https://www.sec.gov/Archives/edgar/data/1370880/000137088021000039/feye-20211004.htm	2026-11-11	Confirmed
50	Mandiant, Form 8-K on closing the products business sale, Oct 2021 (with EDGAR filer-name history)	https://www.sec.gov/Archives/edgar/data/1370880/000137088021000042/feye-20211004.htm	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
51	Mandiant, definitive merger proxy statement (DEFM14A), 2022	https://www.sec.gov/Archives/edgar/data/1370880/000110465922051490/tm2210566-5_defm14a.htm	2026-11-11	Confirmed
52	Mandiant, Exhibit 99.1 press release on the Google agreement, 8 Mar 2022	https://www.sec.gov/Archives/edgar/data/1370880/000110465922031786/tm228582d1_ex99-1.htm	2026-11-11	Confirmed
53	Mandiant, Form 8-K on completion of the Google merger, 12 Sep 2022	https://www.sec.gov/Archives/edgar/data/1370880/000110465922099178/tm2225581d1_8k.htm	2026-11-11	Confirmed
54	NIST NVD, CVE API 2.0 records for CVE-2019-11510, CVE-2020-1472, CVE-2018-13379 and CVE-2019-19781 (the same query per id)	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2019-11510	2026-11-11	Confirmed
55	Malwarebytes, Malwarebytes detects leaked tools from FireEye breach, 10 Dec 2020	malwarebytes.com/blog/news/2020/12/malwarebytes-detects-leaked-tools-from-fireeye-breach	2026-11-11	Confirmed
56	IBM Security Community, FireEye red team tools detection in QRadar, 10 Dec 2020	community.ibm.com/community/user/security/blogs/gladys-koskas1/2020/12/10/...	2026-11-11	Confirmed
57	Wired, Russia's FireEye hack is a statement, but not a catastrophe, Dec 2020 (the Washington Post article it cites was not opened)	wired.com/story/russia-fireeye-hack-statement-not-catastrophe	2026-11-11	Reported
58	CSO Online, FireEye breach explained: how worried should you be?, Dec 2020	csoonline.com/article/3600893/fireeye-breach-explained-how-worried-should-you-be.html	2026-11-11	Reported
59	Schneier on Security, FireEye hacked, 9 Dec 2020 (quoting the New York Times, whose page returned 403)	schneier.com/blog/archives/2020/12/fireeye-hacked.html	2026-11-11	Reported
60	SecurityWeek, FireEye says sophisticated hacker stole red team tools, 8 Dec 2020	securityweek.com/fireeye-says-sophisticated-hacker-stole-red-team-tools	2026-11-11	Reported
61	EMC, Form 8-K Exhibit 99.1, Art Coviello's open letter to RSA customers, 17 Mar 2011	https://www.sec.gov/Archives/edgar/data/790070/000119312511070159/dex991.htm	2026-11-11	Confirmed
62	RSA, Anatomy of an attack, 1 Apr 2011 (Wayback capture)	web.archive.org/web/20110404111547/http://blogs.rsa.com:80/rivner/anatomy-of-an-attack/	2026-11-11	Confirmed
63	EMC, Form 10-Q for Q2 2011	https://www.sec.gov/Archives/edgar/data/790070/000119312511212329/d10q.htm	2026-11-11	Confirmed
64	Bit9, Bit9 and our customers' security, 8 Feb 2013 (Wayback capture)	web.archive.org/web/20130302090357/https://blog.bit9.com/2013/02/08/...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
65	Bit9, Bit9 security incident update, 25 Feb 2013 (Wayback capture)	web.archive.org/web/20130302090353/https://blog.bit9.com/2013/02/25/...	2026-11-11	Confirmed
66	Kaspersky, Eugene Kaspersky's statement on the Duqu attack, 10 Jun 2015	kaspersky.com/blog/kaspersky-statement-duqu-attack/8997	2026-11-11	Confirmed
67	MITRE ATT&CK, software pages S0154, S1071, S0357, S0521, S0012, S0038, S0009 and S0203, with C0024	attack.mitre.org/software/S0154 (and the same path for each id)	2026-11-11	Demonstrated
68	TeamStarWolf library data at main 4be984e7: `data/attack/` (technique, group, campaign and software records, `technique_to_d3fend.jsonl`, `d3fend_countermeasures.jsonl`), `data/weaknesses/` and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
69	TeamStarWolf, SolarWinds and SUNBURST case study (home study for Orion and C0024)	github.com/TeamStarWolf/TeamStarWolf/blob/main/case-studies/SOLARWINDS_SUNBURST.md	2026-11-11	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors, Malware Families, Notable Incidents, CVE Reference
- Red Team Reference, Detection Rules Reference, Incident Response Reference, Vulnerability Management Reference
- Identity Security Reference, Identity and Access Management Reference, Active Directory Attacks, Cloud Attack Reference, Certificate Trust Incident Response
- Supply Chain Security, Supply Chain Security Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Related case studies: SolarWinds and SUNBURST, 2019 to 2021, The Year 2020 in Intrusions, The Year 2021 in Intrusions, Russia-Attributed Threat Actors, United States-Attributed Threat Actors, The Zero-Day Trade and Its Fallout, Stuxnet: The Case Study, The Ransomware Ecosystem, 2019 to 2026
- Groups: G0016 APT29
- Campaigns: C0024 SolarWinds Compromise

- Software: S0559 SUNBURST, S0560 TEARDROP, S0154 Cobalt Strike, S0677 AADInternals, S1071 Rubeus, S0357 Impacket, S0521 BloodHound, S0012 PoisonIvy, S0009 Hikit, S0203 Hydraq, S0038 Duqu
- Techniques: T1098.005 Device Registration, T1195.002 Compromise Software Supply Chain, T1606.002 SAML Tokens, T1552.004 Private Keys, T1484.002 Trust Modification, T1098.001 Additional Cloud Credentials, T1078.004 Cloud Accounts, T1621 Multi-Factor Authentication Request Generation
- CAPEC: CAPEC-678, CAPEC-673, CAPEC-474, CAPEC-21
- Navigator layers, including this study's layer, mandiant-intrusion-2020.json